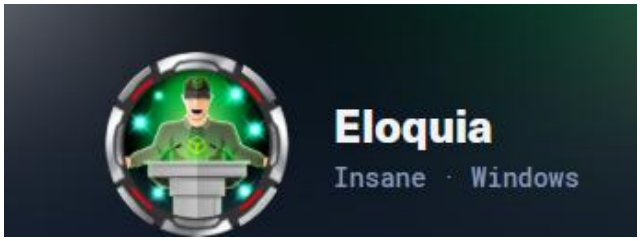


https://app.hackthebox.com/machines/Eloquia?tab=play_machine

RECONNAISSANCE AND ENUMERATION

Step-1:

Nmap Scanning

Scan Results for 10.129.7.222

- **Operating System:** Likely **Windows** (indicated by port 5985).
- **Open Ports:**
  - **80 (HTTP):** A web server is running.
  - **5985 (WSMAN):** Windows Remote Management is active.
- **Status:** The scan checked all 65,535 ports. Only these two were open; the rest (65,533) were filtered/blocked by a firewall.

```
┌──(craw㉿craw)-[~]
└─$ nmap -p- -T4 --min-rate 3000 10.129.7.222

Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-31 15:00 IST
Nmap scan report for 10.129.7.222
Host is up (0.18s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT     STATE SERVICE
80/tcp   open  http
5985/tcp open  wsman

Nmap done: 1 IP address (1 host up) scanned in 66.70 seconds
```

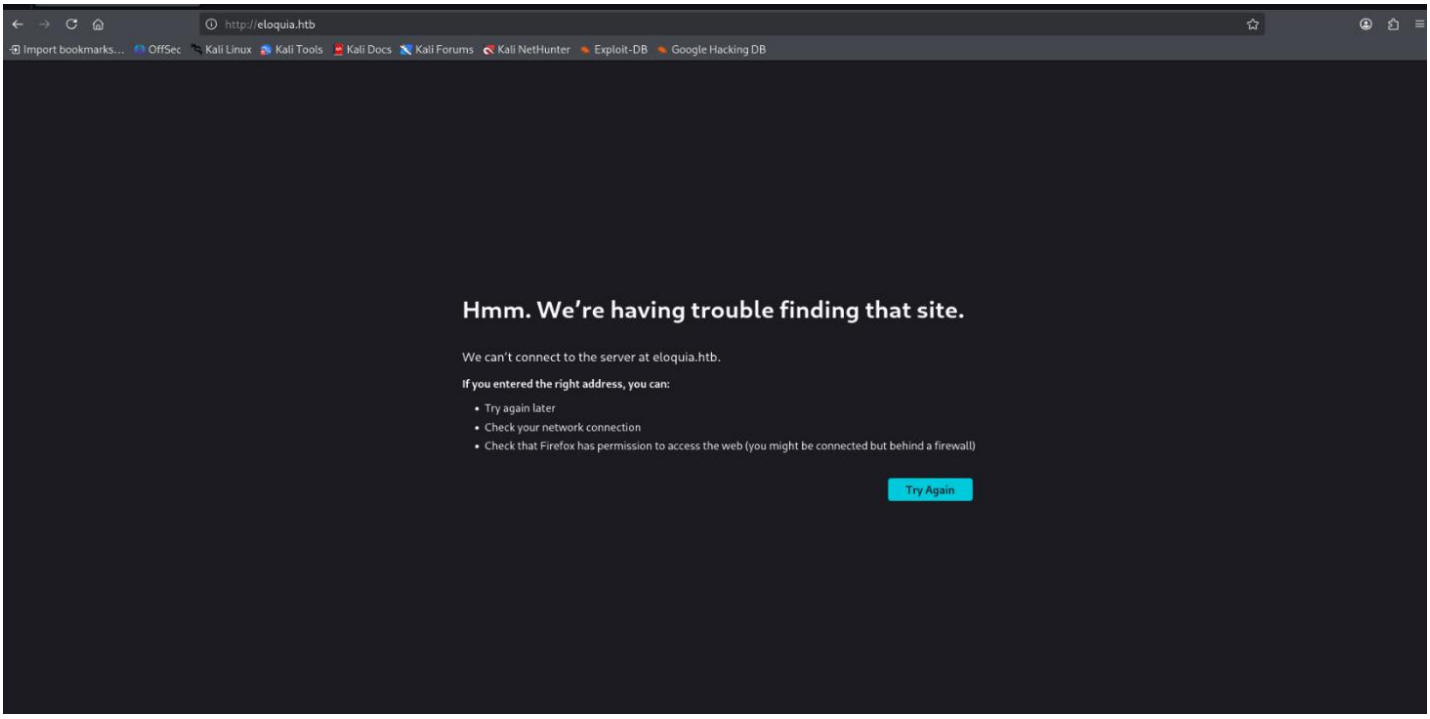
Step-2:

Configure Local DNS Resolution

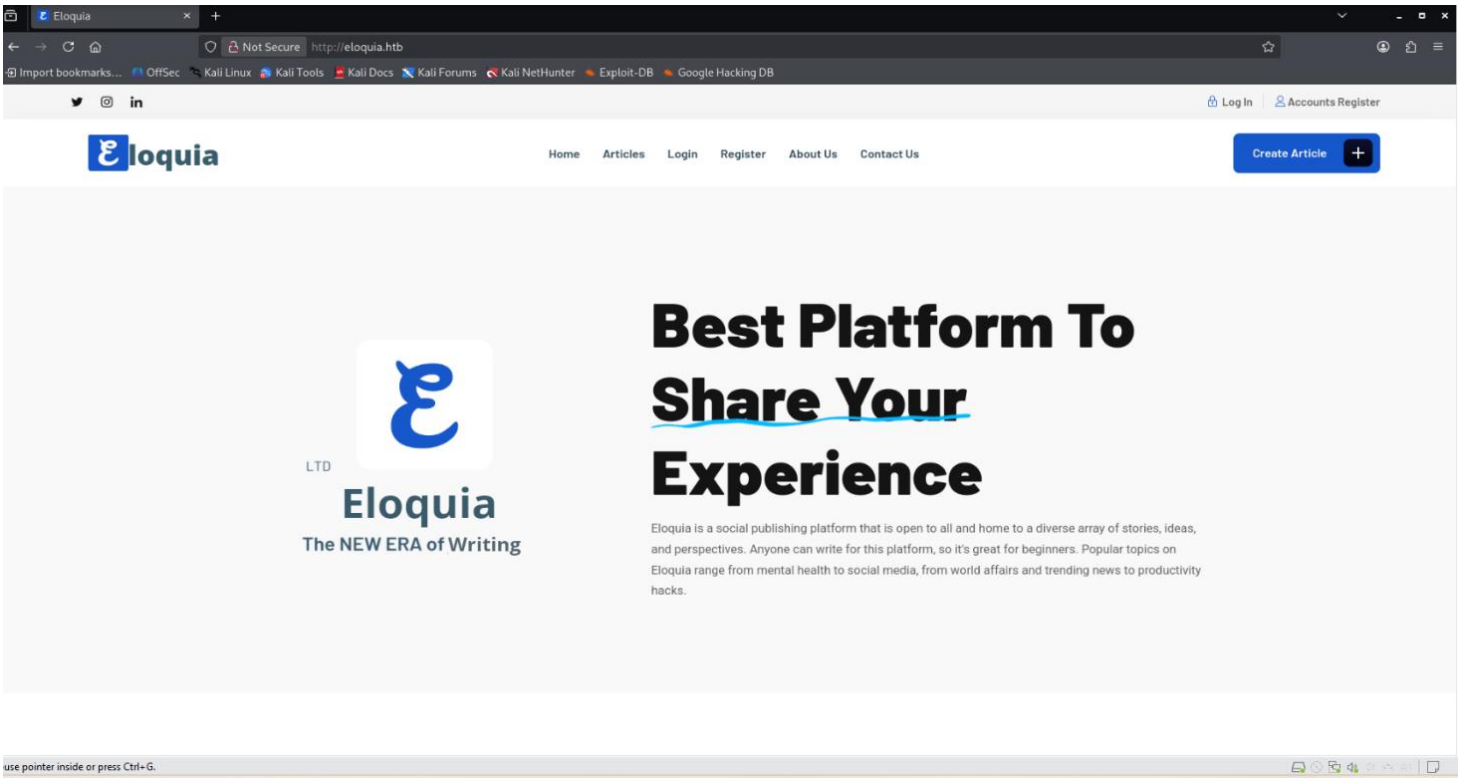
- **The Problem:** Your computer does not know the IP address for `eloquia.htb` because it is a private/internal domain, not a public one.
- **The Fix:** You must manually map the target IP address to the domain name in your **hosts file**.

1. Open your **`/etc/hosts`** file as an administrator (root).
2. Add the following line to the bottom of the file: `10.129.7.222 eloquia.htb`
3. Save the file and refresh the page.

Once you do this, the browser will load the website, and you can continue your testing.



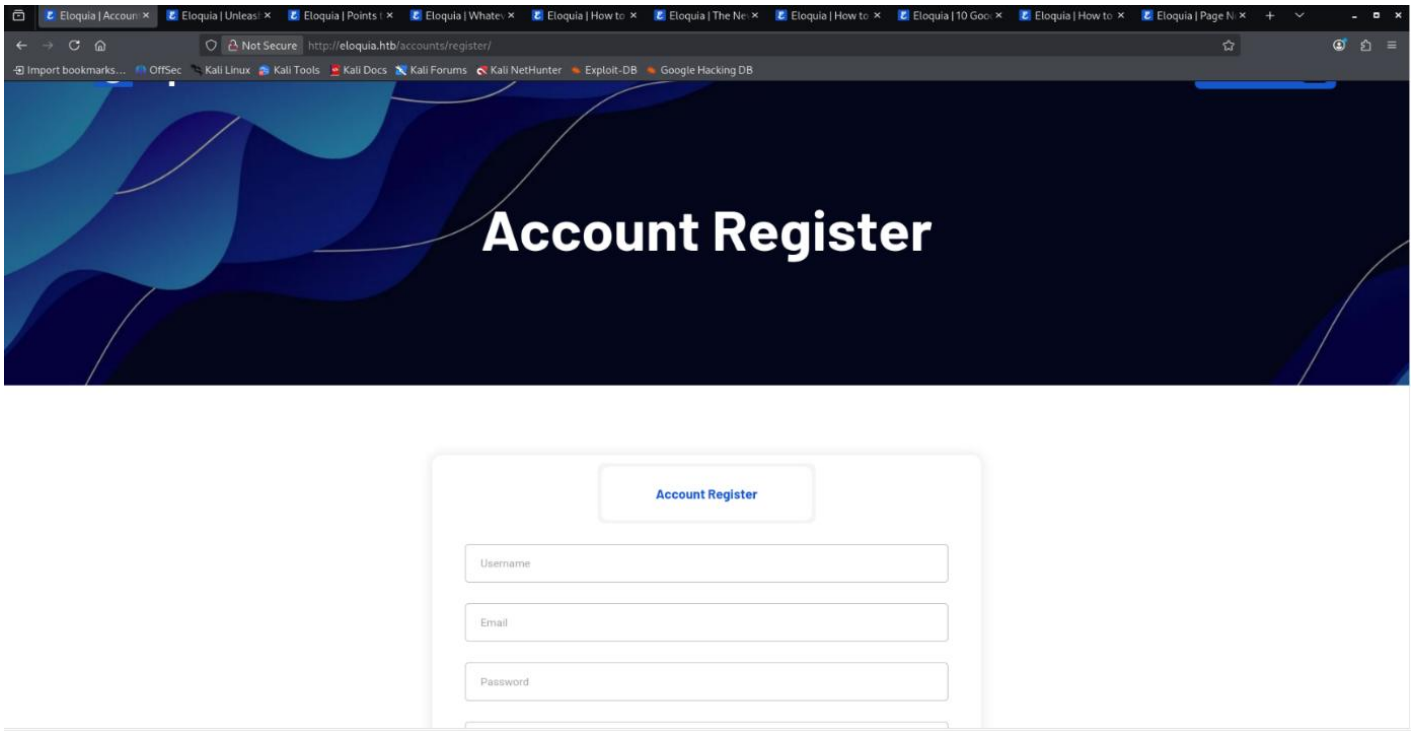
```
GNU nano 8.6                                    /etc/hosts
127.0.0.1       localhost
127.0.1.1       craw.craw       craw
10.129.7.222     eloquia.htb
# The following lines are desirable for IPv6 capable hosts
::1     localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
                                        [ Wrote 7 lines ]
^G Help      ^O Write Out   ^F Where Is    ^K Cut       ^T Execute   ^C Location   M-U Undo
^X Exit      ^R Read File   ^\ Replace     ^U Paste     ^J Justify   ^/ Go To Line M-E Redo
```

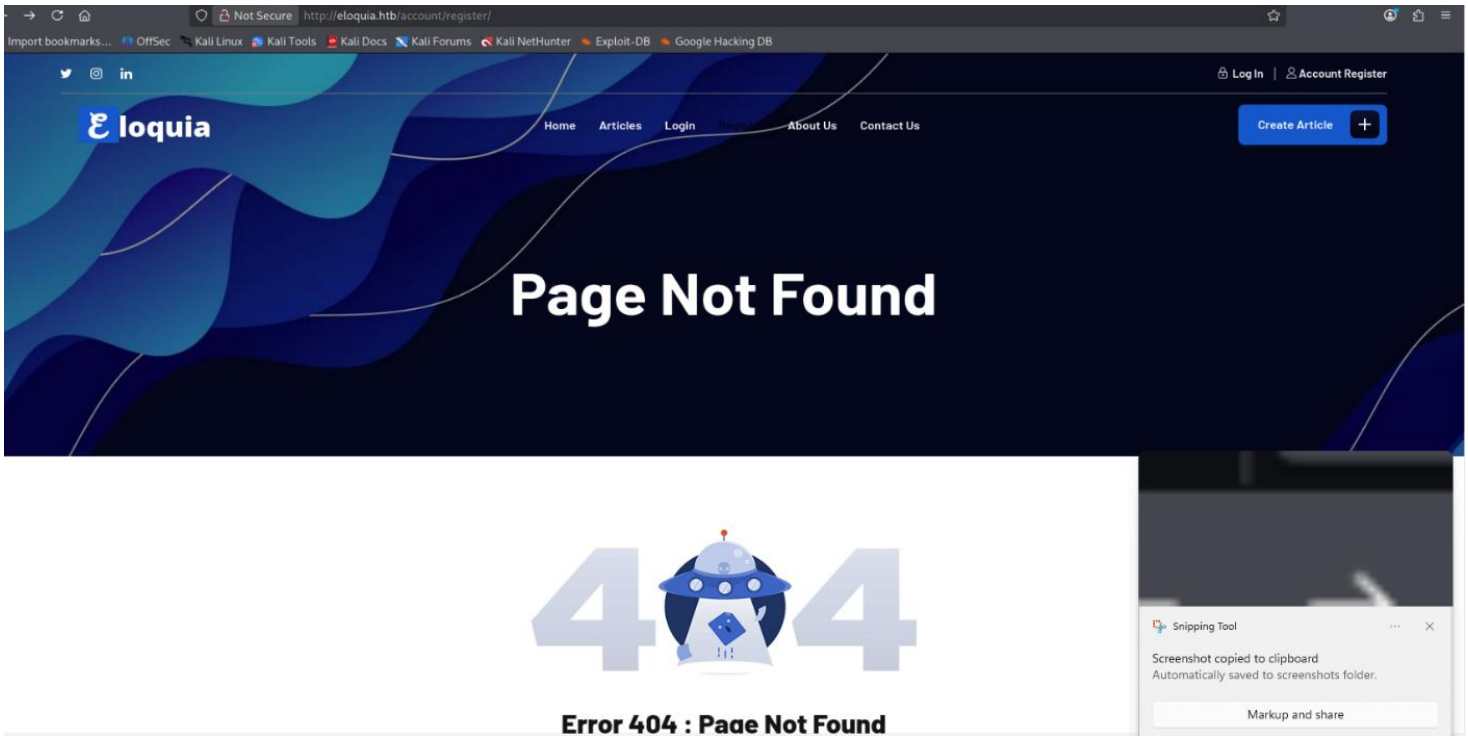


Step 3:

Registration Endpoint Discovery

- **Enumeration:** We systematically checked every accessible page to map the application structure and identify potential input vectors.
- **Findings:**
  - **Valid Endpoint:** We discovered a functional registration form at `/accounts/register/` (plural).
  - **Dead Endpoint:** A similar path at `/account/register/` (singular) does not exist and returns a custom **404 Page Not Found** error.
- **Conclusion:** The application allows public registration, providing a clear path to create a user and access authenticated areas.

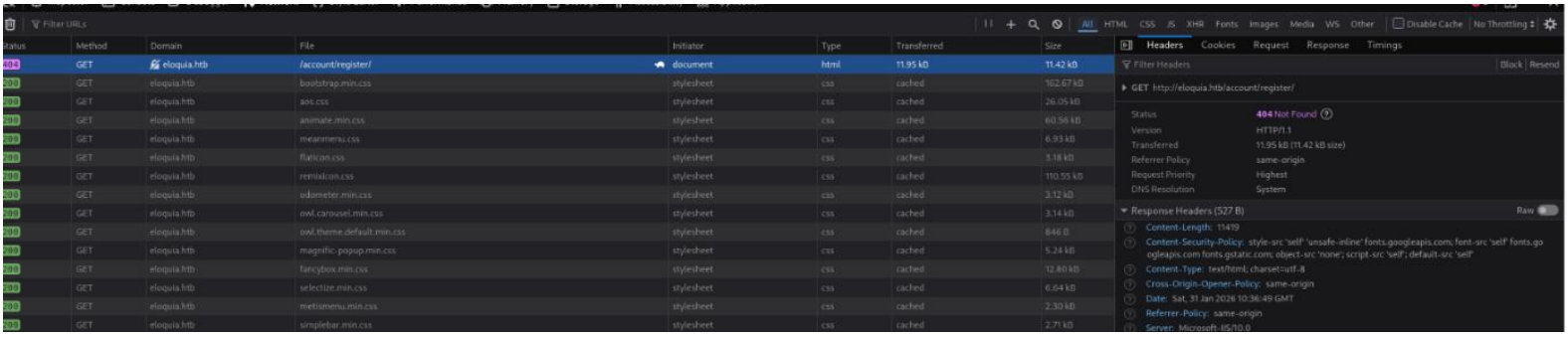


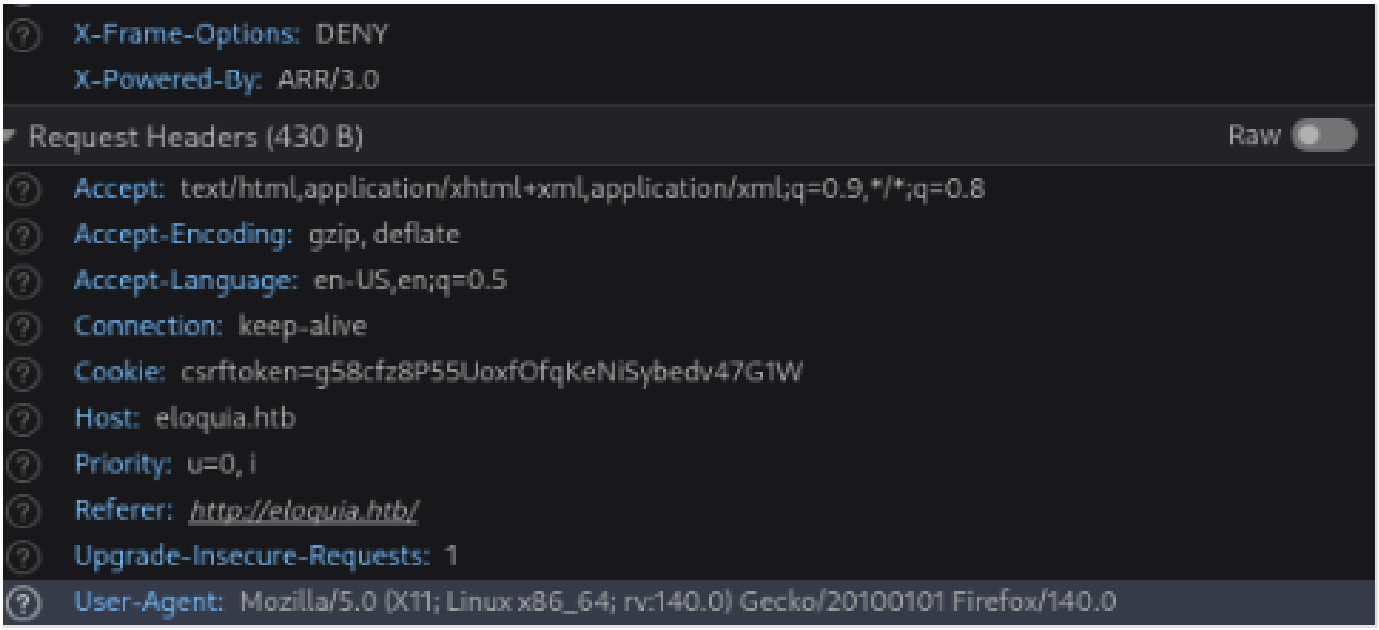


Step 4:

Network Traffic & Header Analysis

- **Error Validation:** We analyzed the browser's network logs and confirmed that the singular path `/account/register/` is invalid, triggering a **404 Not Found** response.
- **Security Token Discovery:** Inspecting the request headers revealed a `csrftoken` cookie being sent to the server. This is a critical finding, as it proves the application uses Cross-Site Request Forgery protection, which we must handle during exploitation.
- **Architecture Confirmation:** The headers re-confirmed the presence of **ARR/3.0**, verifying the reverse proxy setup.

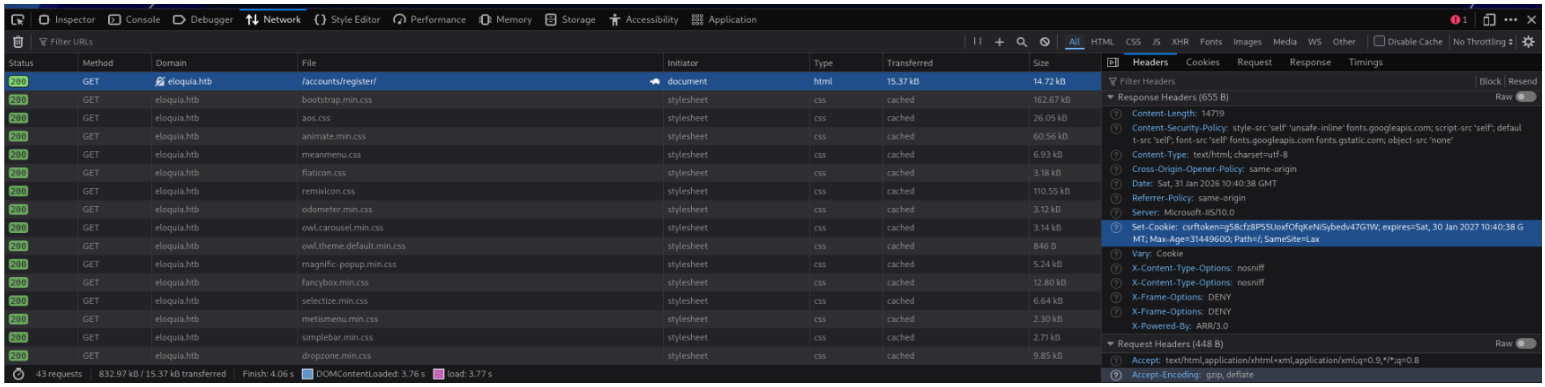




Step 5:

Registration Page Verification

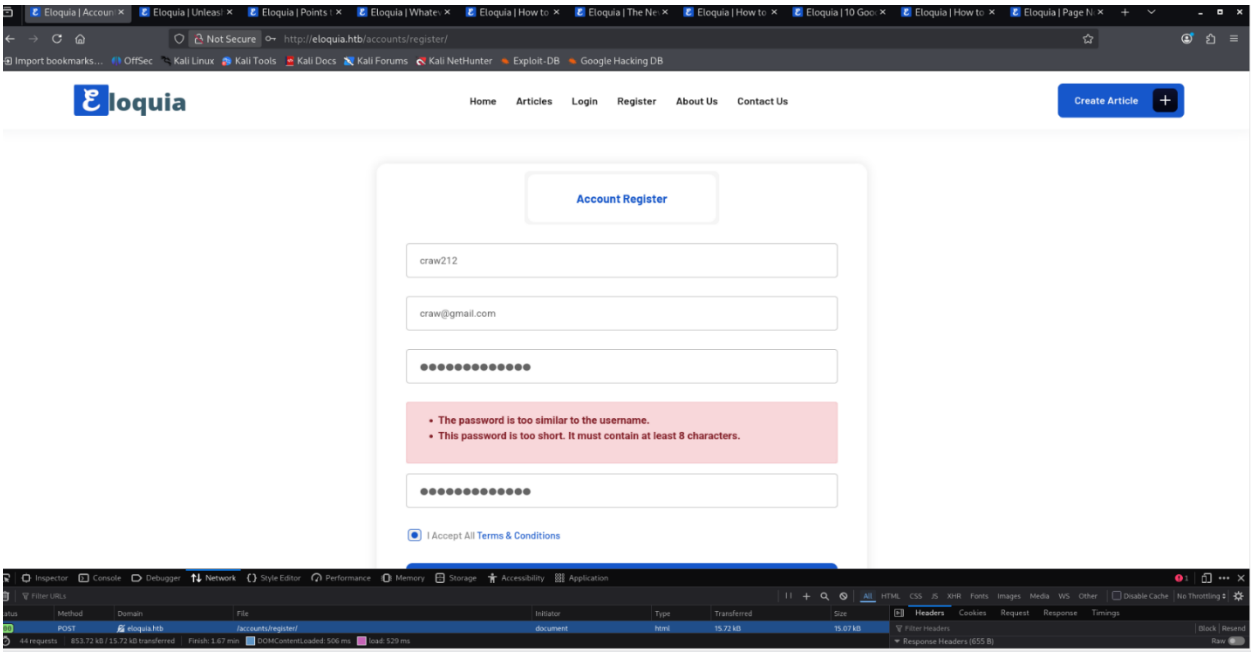
- **Endpoint Confirmation:** We navigated to `/accounts/register/` and received a **200 OK** status, confirming this is the correct page for user creation.
- **Security Mechanism:** The response headers included a `Set-Cookie` directive assigning a `csrftoken`. This confirms the application enforces Cross-Site Request Forgery protection, which means any future automated exploitation scripts must capture and include this token to work.
- **Infrastructure Check:** The `X-Powered-By: ARR/3.0` header persisted, reinforcing that we are interacting with the backend through a Microsoft reverse proxy.

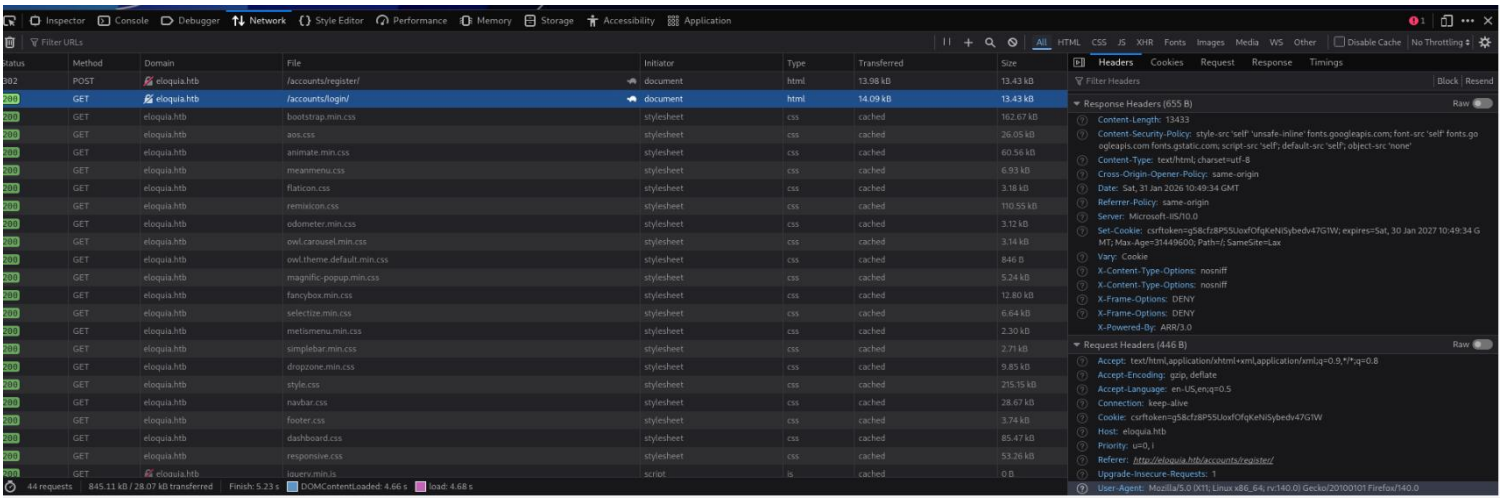


Step 6:

User Registration & Password Policy Analysis

- **Policy Enumeration:** During the account creation process, we identified strict password constraints. The application rejected weak credentials, explicitly stating that passwords must be at least 8 characters long and cannot be similar to the username.
- **Successful Execution:** After meeting these complexity requirements, the registration request returned a **302 Found** status code.
- **Workflow Validation:** This redirect automatically transitioned the session to `/accounts/login/`, confirming that the user account was successfully created and is ready for authentication.

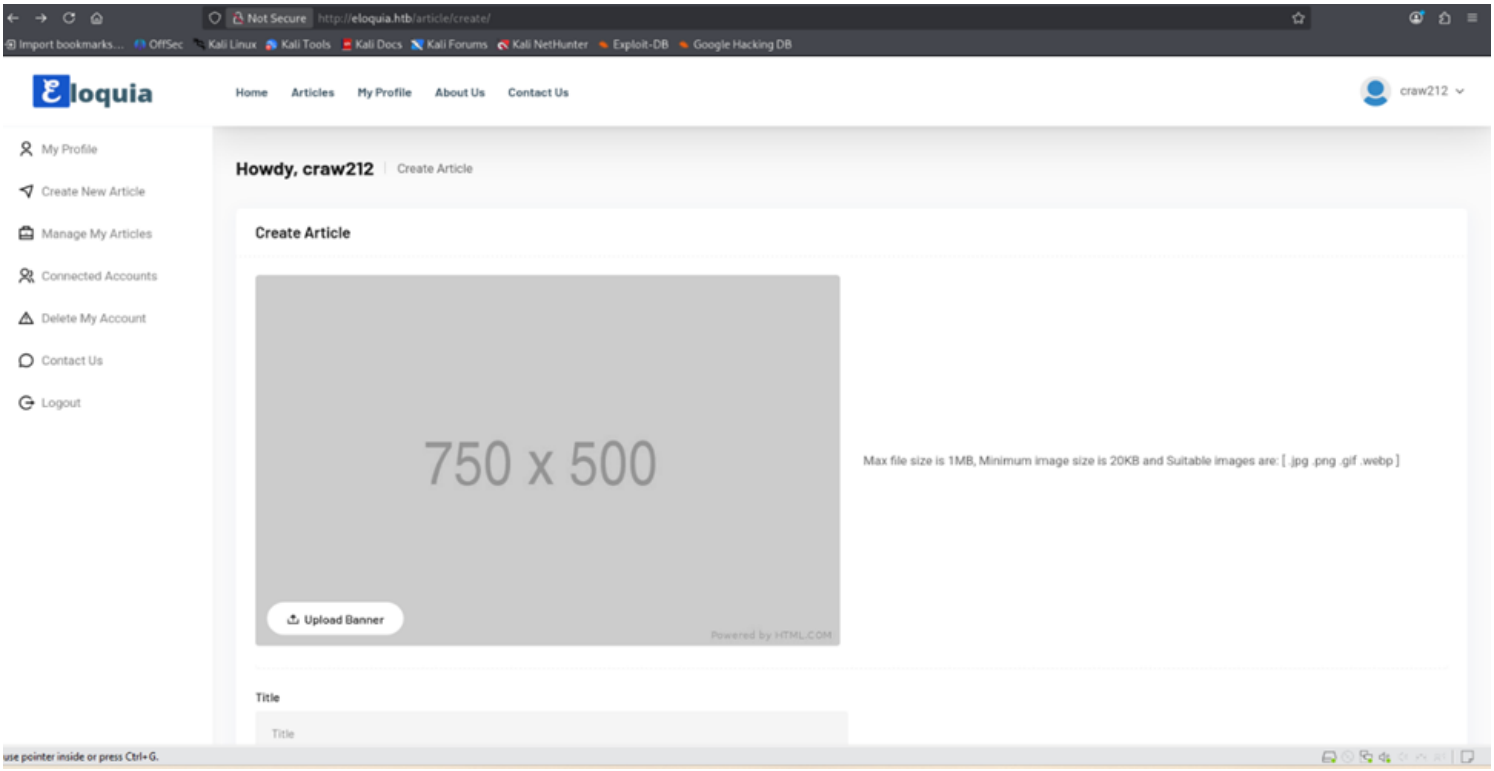


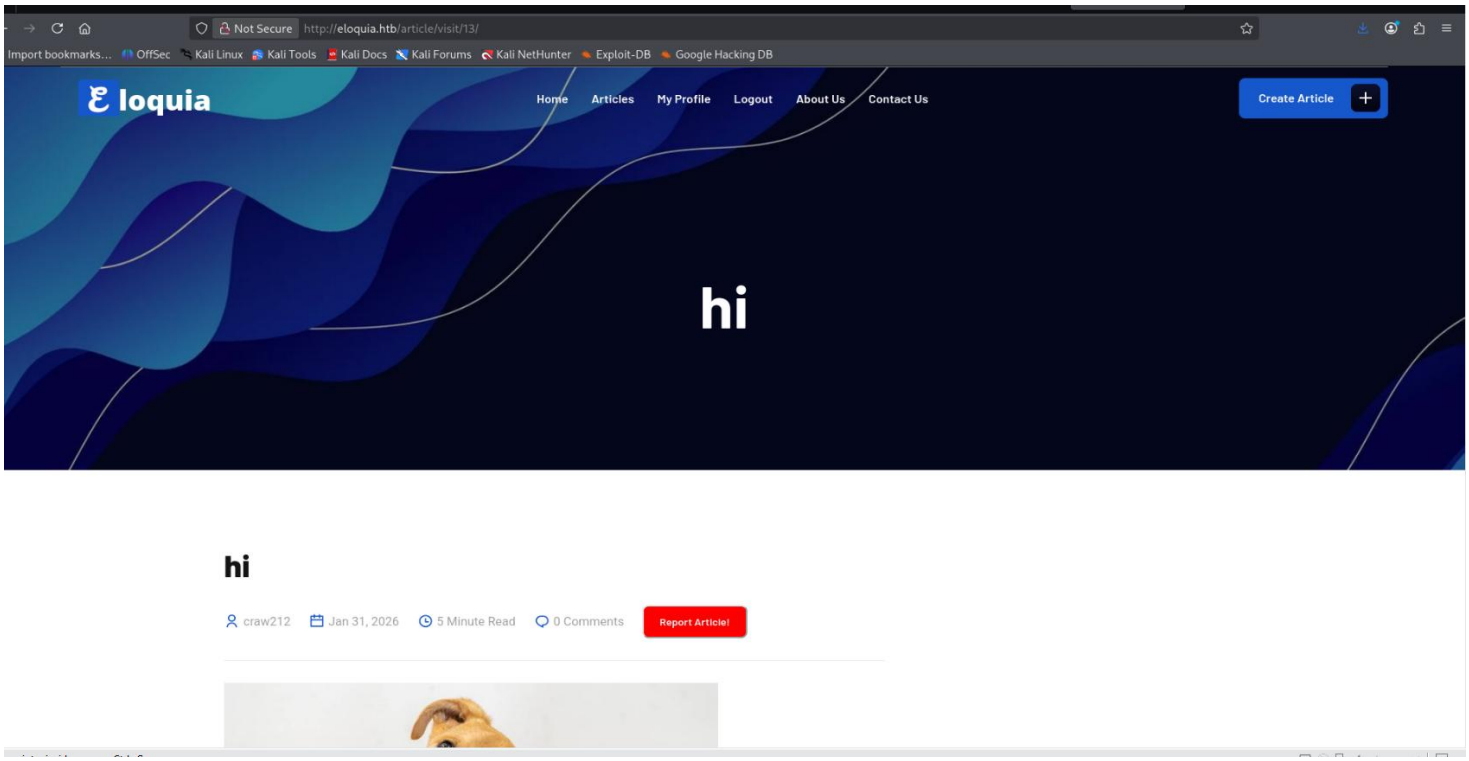


Step 7:

Authenticated Attack Surface Analysis

- **Feature Discovery:** Upon logging in, we accessed the "Create Article" dashboard, which exposes a file upload interface for article banners.
- **Constraint Enumeration:** The application displays specific validation rules for uploads: files must be between **20KB and 1MB** and restricted to image formats (`.jpg`, `.png`, `.gif`, `.webp`).
- **Functionality Test:** We successfully uploaded a compliant image and verified that the server processes and renders the file on the published article page, confirming this as a viable vector for file-based attacks.

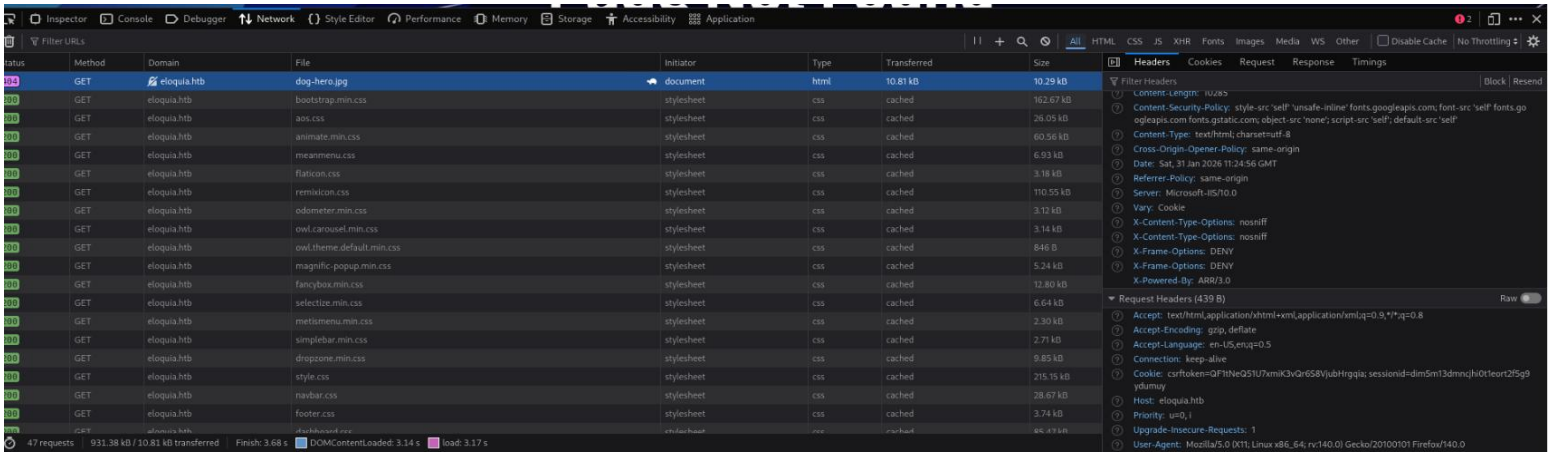


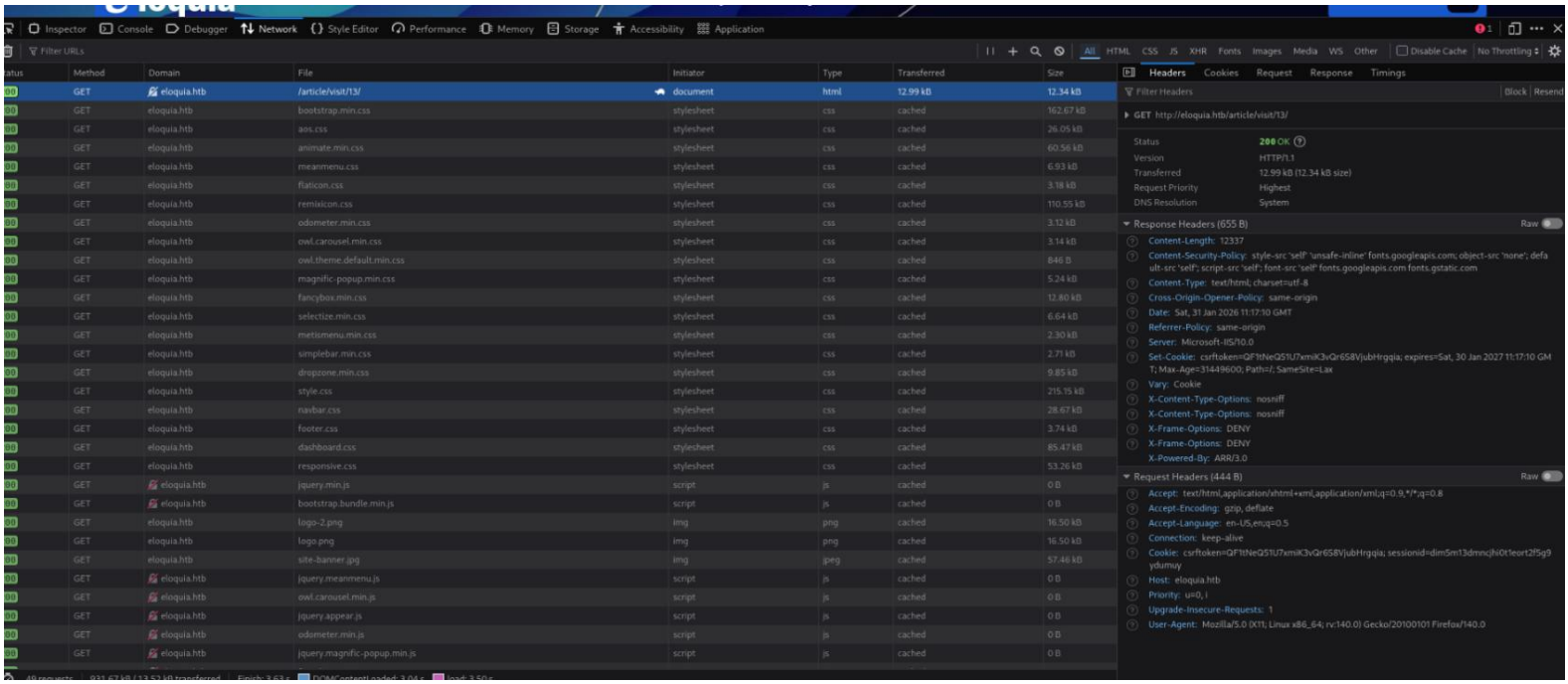


Step 8:

File Path Analysis

- **Direct Access Attempt:** We attempted to access the uploaded image directly at the web server's root (`http://eloquia.htb/Dog-hero.jpg`) to check for loose file permissions, but the server returned a **404 Not Found** error.
- **Contextual Verification:** We then navigated to the created article page at `/article/visit/13/`, which returned a **200 OK** status.
- **Conclusion:** This indicates that while the upload was successful, the application does not store user-generated content in the web root. We must inspect the article's source code to identify the actual upload directory (e.g., `/media/` or `/static/`) to plan our shell execution path.

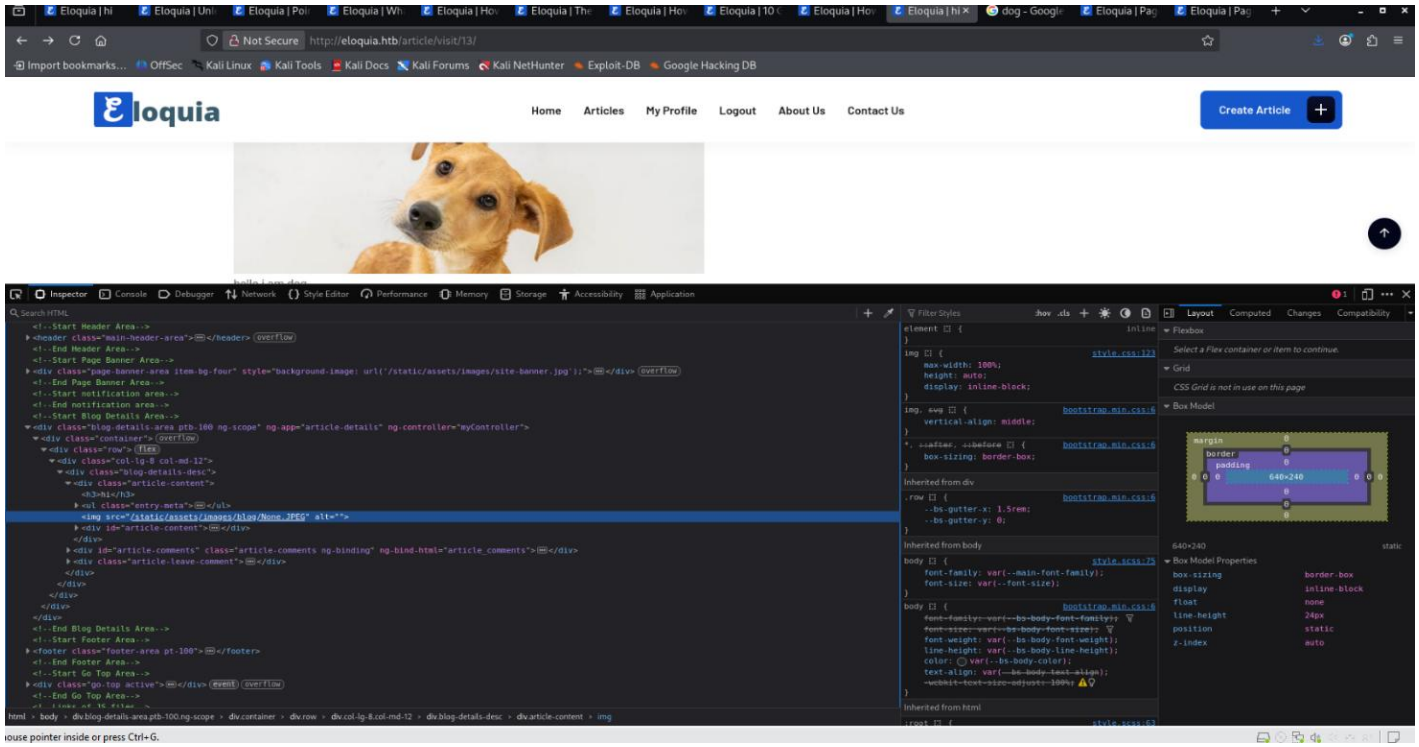

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application
Filter URLs
All HTML CSS JS XHR Fonts Images Media WS Other Disable Cache No Throttling
Status Method Domain File Initiator Type Transferred Size
304 GET eloquia.htb dog-hero.jpg document html 10.81 kB 10.29 kB
304 GET eloquia.htb bootstrap.min.css stylesheet css cached 162.67 kB
304 GET eloquia.htb aos.css stylesheet css cached 26.05 kB
304 GET eloquia.htb animate.min.css stylesheet css cached 60.56 kB
304 GET eloquia.htb meanmenu.css stylesheet css cached 6.93 kB
304 GET eloquia.htb flaticon.css stylesheet css cached 3.18 kB
304 GET eloquia.htb remixicon.css stylesheet css cached 110.55 kB
304 GET eloquia.htb odometer.min.css stylesheet css cached 3.12 kB
304 GET eloquia.htb owl.carousel.min.css stylesheet css cached 3.14 kB
304 GET eloquia.htb owl.theme.default.min.css stylesheet css cached 846 B
304 GET eloquia.htb magnific-popup.min.css stylesheet css cached 5.24 kB
304 GET eloquia.htb fancybox.min.css stylesheet css cached 12.80 kB
304 GET eloquia.htb selectize.min.css stylesheet css cached 6.64 kB
304 GET eloquia.htb metismenu.min.css stylesheet css cached 2.30 kB
304 GET eloquia.htb simplebar.min.css stylesheet css cached 2.71 kB
304 GET eloquia.htb dropzone.min.css stylesheet css cached 9.85 kB
304 GET eloquia.htb style.css stylesheet css cached 215.15 kB
304 GET eloquia.htb navbar.css stylesheet css cached 28.67 kB
304 GET eloquia.htb footer.css stylesheet css cached 3.74 kB
47 requests 931.38 kB / 10.81 kB transferred Finish: 3.68 s DOMContentLoaded: 3.14 s load: 3.17 s
Headers Cookies Request Response Timings
Filter Headers Block Resend
Content-Length: 10285
Content-Security-Policy: style-src 'self' 'unsafe-inline' fonts.googleapis.com; font-src 'self' fonts.gogleapis.com fonts.gstatic.com; object-src 'none'; script-src 'self'; default-src 'self'
Content-Type: text/html; charset=utf-8
Cross-Origin-Opener-Policy: same-origin
Date: Sat, 31 Jan 2026 11:24:56 GMT
Referrer-Policy: same-origin
Server: Microsoft-IIS/10.0
Vary: Cookie
X-Content-Type-Options: nosniff
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
X-Frame-Options: DENY
X-Powered-By: ARR/3.0
Request Headers (439 B) Raw
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Cookie: csrftoken=QF1tNeQS1U7xmiK3vQr658VjubHrgqia; sessionid=dim5m13dmncjhi0t1eort2f5g9ydumuy
Host: eloquia.htb
Priority: u=0, i
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0


Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application
Filter URLs
All HTML CSS JS XHR Fonts Images Media WS Other Disable Cache No Throttling
Status Method Domain File Initiator Type Transferred Size
200 GET eloquia.htb /article/visit/13/ document html 12.99 kB 12.34 kB
304 GET eloquia.htb bootstrap.min.css stylesheet css cached 162.67 kB
304 GET eloquia.htb aos.css stylesheet css cached 26.05 kB
304 GET eloquia.htb animate.min.css stylesheet css cached 60.56 kB
304 GET eloquia.htb meanmenu.css stylesheet css cached 6.93 kB
304 GET eloquia.htb flaticon.css stylesheet css cached 3.18 kB
304 GET eloquia.htb remixicon.css stylesheet css cached 110.55 kB
304 GET eloquia.htb odometer.min.css stylesheet css cached 3.12 kB
304 GET eloquia.htb owl.carousel.min.css stylesheet css cached 3.14 kB
304 GET eloquia.htb owl.theme.default.min.css stylesheet css cached 846 B
304 GET eloquia.htb magnific-popup.min.css stylesheet css cached 5.24 kB
304 GET eloquia.htb fancybox.min.css stylesheet css cached 12.80 kB
304 GET eloquia.htb selectize.min.css stylesheet css cached 6.64 kB
304 GET eloquia.htb metismenu.min.css stylesheet css cached 2.30 kB
304 GET eloquia.htb simplebar.min.css stylesheet css cached 2.71 kB
304 GET eloquia.htb dropzone.min.css stylesheet css cached 9.85 kB
304 GET eloquia.htb style.css stylesheet css cached 215.15 kB
304 GET eloquia.htb navbar.css stylesheet css cached 28.67 kB
304 GET eloquia.htb footer.css stylesheet css cached 3.74 kB
304 GET eloquia.htb dashboard.css stylesheet css cached 85.47 kB
304 GET eloquia.htb responsive.css stylesheet css cached 53.26 kB
304 GET eloquia.htb jquery.min.js script js cached 0 B
304 GET eloquia.htb bootstrap.bundle.min.js script js cached 0 B
304 GET eloquia.htb logo-2.png img png cached 16.50 kB
304 GET eloquia.htb logo.png img png cached 16.50 kB
304 GET eloquia.htb site-banner.jpg img jpeg cached 57.46 kB
304 GET eloquia.htb jquery.meanmenu.js script js cached 0 B
304 GET eloquia.htb owl.carousel.min.js script js cached 0 B
304 GET eloquia.htb jquery.appear.js script js cached 0 B
304 GET eloquia.htb odometer.min.js script js cached 0 B
304 GET eloquia.htb jquery.magnific-popup.min.js script js cached 0 B
Headers Cookies Request Response Timings
Filter Headers Block Resend
GET http://eloquia.htb/article/visit/13/
Status 200 OK
Version HTTP/1.1
Transferred 12.99 kB (12.34 kB size)
Request Priority Highest
DNS Resolution System
Response Headers (655 B) Raw
Content-Length: 12337
Content-Security-Policy: style-src 'self' 'unsafe-inline' fonts.googleapis.com; object-src 'none'; default-src 'self'; script-src 'self'; font-src 'self' fonts.googleapis.com fonts.gstatic.com
Content-Type: text/html; charset=utf-8
Cross-Origin-Opener-Policy: same-origin
Date: Sat, 31 Jan 2026 11:17:10 GMT
Referrer-Policy: same-origin
Server: Microsoft-IIS/10.0
Set-Cookie: csrftoken=QF1tNeQS1U7xmiK3vQr658VjubHrgqia; expires=Sat, 30 Jan 2027 11:17:10 GMT; Max-Age=31449600; Path=/; SameSite=Lax
Vary: Cookie
X-Content-Type-Options: nosniff
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
X-Frame-Options: DENY
X-Powered-By: ARR/3.0
Request Headers (444 B) Raw
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Cookie: csrftoken=QF1tNeQS1U7xmiK3vQr658VjubHrgqia; sessionid=dim5m13dmncjhi0t1eort2f5g9ydumuy
Host: eloquia.htb
Priority: u=0, i
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0

Step 9:

Backend Behavior Analysis (The "None.JPEG" Anomaly)

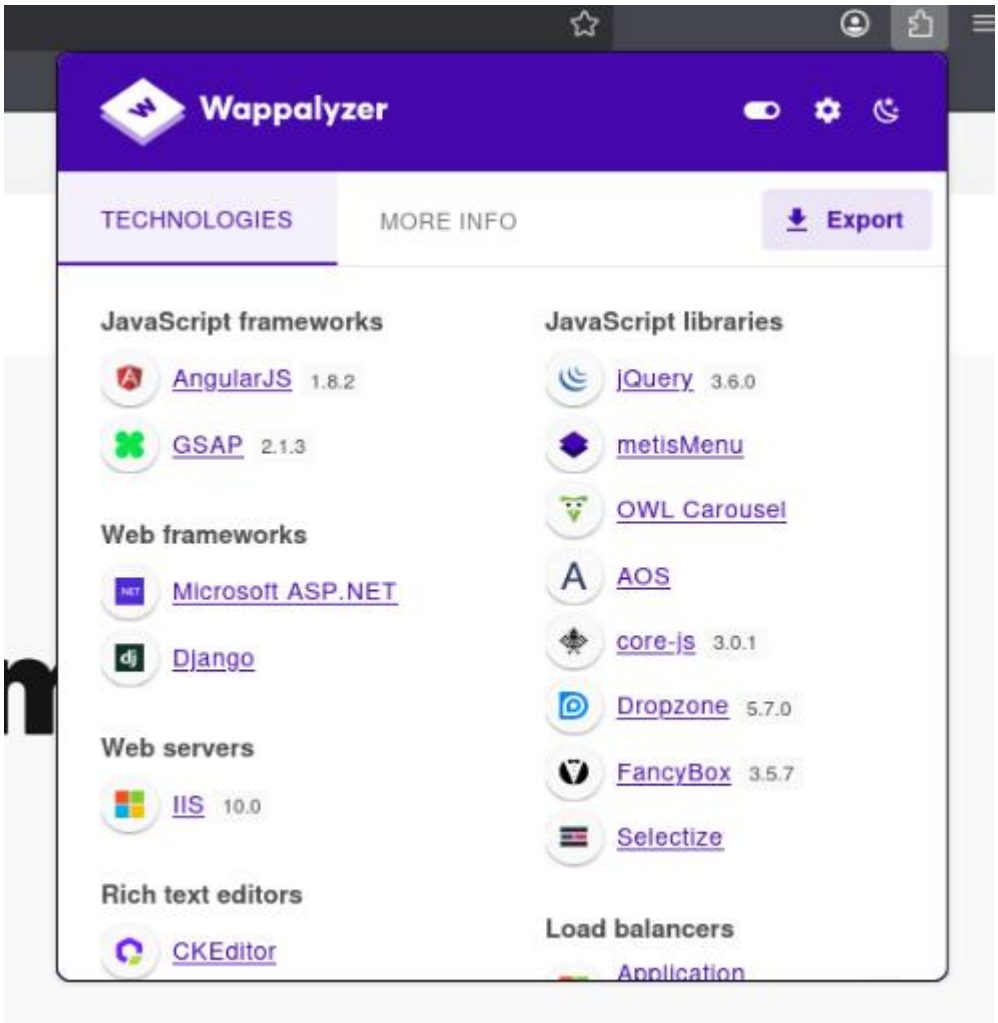
- **Path Verification:** We inspected the HTML source to find the exact location of our uploaded file. The code revealed the path: `/static/assets/images/blog/None.JPEG`.
- **Renaming Anomaly:** The server automatically renamed our uploaded image to **"None.JPEG"**.
- **Technology Fingerprint:** This is a significant finding. In Python (specifically frameworks like Django), if a filename variable is empty (`None`) and gets converted to a string, it becomes the word "None." This strongly confirms the backend is running **Python**.



Step 10:

Technology Stack Confirmation

- **Verification:** To confirm our suspicion about the backend, we ran **Wappalyzer**. It explicitly detected **Django** as the web framework.
- **Correlation:** This definitively proves that the "None.JPEG" error was caused by a Python backend, validating our theory that the application logic is running on Python behind the IIS reverse proxy.
- **Component Identification:** The scan also identified **Dropzone 5.7.0**, which is the JavaScript library responsible for the file upload interface we previously tested.



Step 11:

Step: Vulnerability Identification (CVE-2021-22204)

- **Metadata Extraction:** When we uploaded the image, the server processed it and displayed detailed metadata, including file permissions, MIME type, and image dimensions.
- **Critical Finding:** The output explicitly lists the **ExifTool Version Number** as **12.25**.
- **Vulnerability Context:** This specific version (12.25) is known to be vulnerable to **CVE-2021-22204**. This is a critical remote code execution (RCE) vulnerability where improperly sanitized DjVu metadata can trigger arbitrary command execution during the parsing process. This confirms our primary exploitation vector.

None.JPEG

File Metadata

File Type: image/jpeg
Error: 0
Upload Size: 10622

exiftool:

Name	Value
ExifTool Version Number	12.25
File Name	phpt6ZGPS
Directory	/tmp
File Size	10 KiB
File Modification Date/Time	2026:01:31 11:47:39+00:00
File Access Date/Time	2026:01:31 11:47:39+00:00
File Inode Change Date/Time	2026:01:31 11:47:39+00:00
File Permissions	-rw-------
File Type	JPEG
File Type Extension	jpg
MIME Type	image/jpeg
JFIF Version	1.01
Resolution Unit	None
X Resolution	1
Y Resolution	1
Image Width	640
Image Height	240
Encoding Process	Baseline DCT, Huffman coding
Bits Per Sample	8
Color Components	3
Y Cb Cr Sub Sampling	YCbCr4:2:0 (2 2)
Image Size	640x240
Megapixels	0.154

dog-hero.jpg

File Metadata

File Type: image/jpeg
Error: 0
Upload Size: 31158

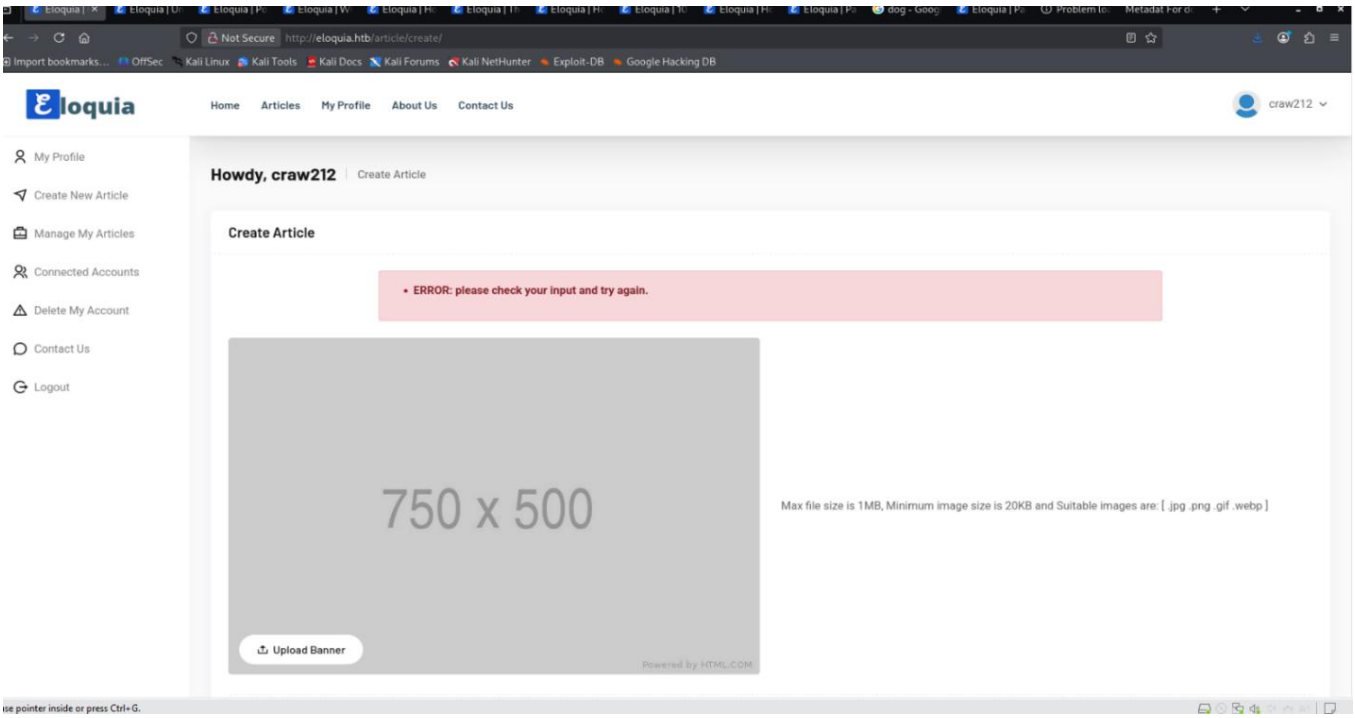
exiftool:

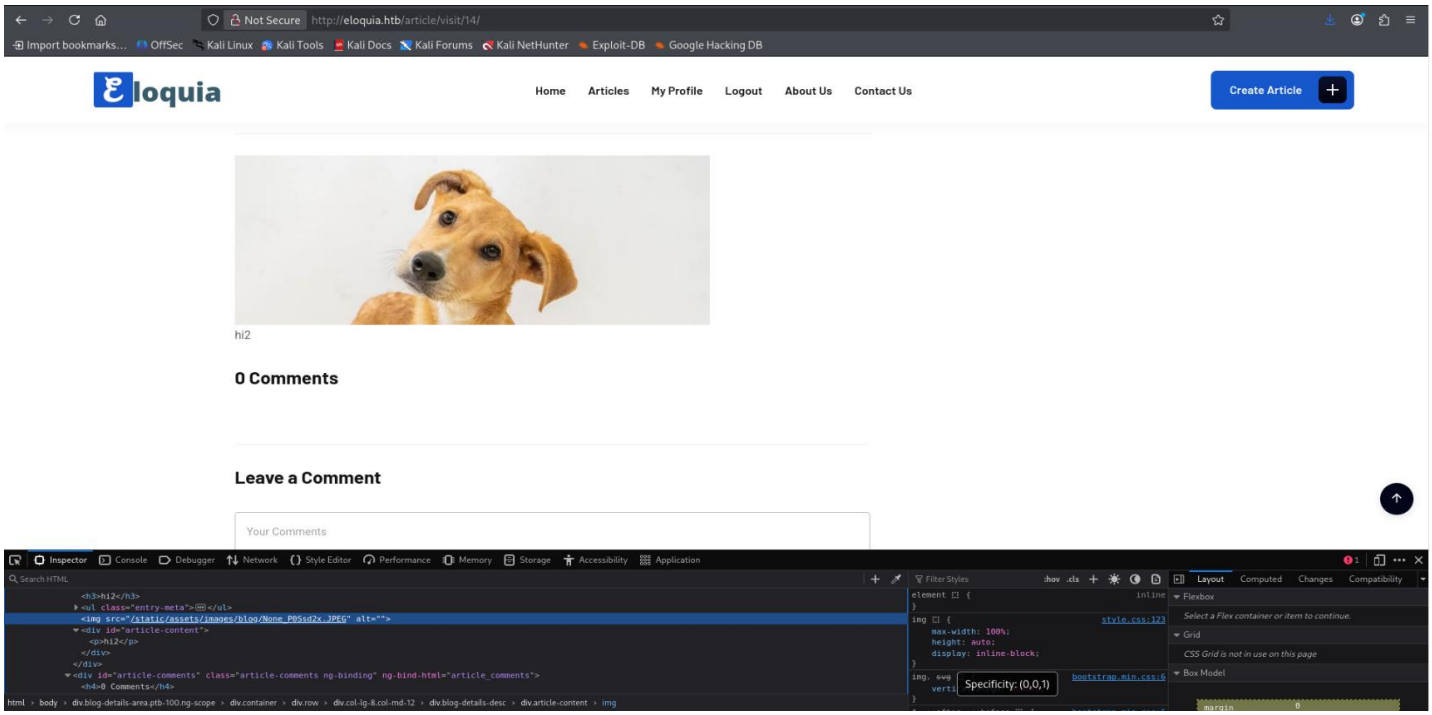
Name	Value
ExifTool Version Number	12.25
File Name	phpwvONaQ
Directory	/tmp
File Size	30 KiB
File Modification Date/Time	2026:01:31 11:48:47+00:00
File Access Date/Time	2026:01:31 11:48:47+00:00
File Inode Change Date/Time	2026:01:31 11:48:47+00:00
File Permissions	-rw-------
File Type	JPEG
File Type Extension	jpg
MIME Type	image/jpeg
JFIF Version	1.02
Resolution Unit	inches
X Resolution	72
Y Resolution	72
Image Width	1500
Image Height	563
Encoding Process	Progressive DCT, Huffman coding
Bits Per Sample	8
Color Components	3
Y Cb Cr Sub Sampling	YCbCr4:4:4 (1 1)
Image Size	1500x563
Megapixels	0.845

Step 12:

Input Validation & Logic Analysis

- **Constraint Verification:** We attempted to upload `none.jpg`, but the server rejected it with an error. This confirms the application strictly enforces the **20KB minimum file size** rule displayed on the UI, as our payload was too small.
- **Successful Bypass:** We uploaded a larger file, `dog-hero.jpg` (approx. 30KB), which passed the validation checks and was successfully stored on the server.
- **Backend Behavior Confirmation:** The server renamed the valid file to `None_P0Ssd2x.JPEG`. This random suffix is a standard **Django** feature used to prevent filename collisions. Combined with the "None" prefix, this definitively proves the backend logic is mishandling the filename variable (converting a Python `None` object to a string) before saving it.





Step 13:

Automated Server Vulnerable Scanning

- **Action:** We performed a **Nikto** scan against the target IP to check for common server misconfigurations and outdated software.
- **Result:** The scan re-confirmed the server is running **Microsoft-IIS/10.0** and validated the global redirect rule pointing to `http://eloquia.htb/`.
- **Analysis:** While Nikto flagged missing security headers (like `X-Frame-Options`), it reported "No CGI Directories found," suggesting that standard IIS exploits are unlikely to work. This reinforces that our primary path to exploitation lies within the custom **Django** application logic we identified earlier.

```
┌──(craw㉿craw)-[~]
└─$ nikto -h http://10.129.244.81
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          10.129.244.81
+ Target Hostname:    10.129.244.81
+ Target Port:        80
+ Start Time:         2026-02-03 10:08:06 (GMT5.5)
---------------------------------------------------------------------------
+ Server: Microsoft-IIS/10.0
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page / redirects to: http://eloquia.htb/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ 8103 requests: 1 error(s) and 2 item(s) reported on remote host
+ End Time:         2026-02-03 10:23:32 (GMT5.5) (926 seconds)
```

Step 14:

Domain Configuration & Fingerprinting

- **Server Verification:** We verified the fix using `curl`, which returned a **200 OK** status. The response headers revealed critical information about the target:

  - **Server:** Microsoft-IIS/10.0
  - **Component:** ARR/3.0 (Application Request Routing) – *This indicates the server is using a reverse proxy, which is a key area to investigate for vulnerabilities.*

```
Session  Actions  Edit  View  Help
┌──(craw㉿craw)-[~]
└─$ curl -I http://eloquia.htb/

HTTP/1.1 200 OK
Content-Length: 35822
Content-Type: text/html; charset=utf-8
Vary: Cookie
Server: Microsoft-IIS/10.0
Content-Security-Policy: style-src 'self' 'unsafe-inline' fonts.googleapis.com; default-src 'self'; object-src 'none'; font-src 'self' fonts.googleapis.com fonts.gstatic.com; script-src 'self'
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Referrer-Policy: same-origin
Cross-Origin-Opener-Policy: same-origin
X-Powered-By: ARR/3.0
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Date: Sat, 31 Jan 2026 09:48:44 GMT
```

Step 15:

Session Cookie Analysis

- **Action:** We isolated the HTTP headers to check for session management using the command `curl -I http://eloquia.htb | grep -i set-cookie`.
- **Result:** The command returned no output. This confirms that the web server does not issue a `Set-Cookie` header (and thus no session ID) when a user simply visits the landing page.

```
┌──(craw㉿craw)-[~]
└─$ curl -I http://eloquia.htb | grep -i set-cookie

 % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
 0 35822    0     0    0     0     0     0  --:--:-- --:--:-- --:--:--     0
```